
PORTAS

O que elas fazem nas
redes???



Do livro Hacking com Kali Linux
Técnicas de invasão para testes de invasão
James Broad e Andrew Bindner
Novatec - 2017

ENTENDENDO O TRÁFEGO DE REDE

Para algumas pessoas, o **tráfego** de rede pode ser **difícil de entender**; entretanto uma compreensão básica do assunto é necessária para tirar o máximo de proveito da fase de **scanning**. O tráfego de rede consiste na **comunicação eletrônica** que ocorre entre os **sistemas de computadores conectados** por meio de vários métodos diferentes. **Atualmente**, os métodos mais comuns que se pode ter **conexão** de rede são o **Wired Ethernet** e **Wireless Ethernet**. É necessário entender os princípios fundamentais da comunicação Ethernet. Hoje falaremos sobre as **portas** e os **firewalls**, os protocolos **IP**, incluindo o **TCP** (Transmission Control Protocol), o **UDP** (User Datagram Protocol) e o **ICMP** (Internet Control Management Protocol).

ENTENDENDO AS PORTAS E OS FIREWALLS

Um dos métodos mais básicos para defender uma rede consiste em implementar um firewall entre a rede interna, que normalmente é a rede corporativa, e o restante do mundo que provavelmente é a internet. Um firewall é simplesmente um dispositivo computacional com 2 ou mais placas de rede que serve como uma porta de entrada para a rede. As listas de controle de acesso monitoram rigidamente o tráfego de saída (*egress*) e o tráfego de entrada (*ingress*). somente o tráfego que atender os critérios associados aos controles de acesso terão permissão para passar, enquanto o restante será descartado pelo firewall. isso é feito por meio da abertura é do fechamento de portas para permitir ou para impedir a passagem do tráfego.

ENTENDENDO AS PORTAS E OS FIREWALLS

As **portas** correspondem aos **diferentes canais** usados para comunicação entre computadores, existem **65535 portas TCP** e outras **65535 portas UDP** que podem ser usadas para a comunicação. Uma **pequena porcentagem** das portas foi projetada para ter um **propósito específico**, porém elas não ficam restritas a esse tipo de uso. Por exemplo, a porta **TCP 80** é usada com mais frequência para o **tráfego web** normal da internet que utiliza **HTTP**, ou o protocolo de transferência de hipertexto, mas **outros tipos de tráfego podem passar por essa porta** e o tráfego de internet pode ser transmitido por meio de outras portas.

ENTENDENDO AS PORTAS E OS FIREWALLS

Uma maneira de **pensar** nas portas é imaginar um **prédio** grande com **portas** que conduzem a **diferentes salas**, cada uma dessas salas possui uma **equipe** de funcionários que realizam um **trabalho específico** e **administra diferentes funções**. O **escritório** que fica atrás da **porta 80** cuida das solicitações da **página web** que chegaram. É **possível** que o departamento de **web** seja **transferido**, por exemplo, **para outro escritório** que fica na sala **8080**, embora ele **continue a executar** as **mesmas funções** nesse **novo local**, ou seja **continue a lidar** com as solicitações da **web**.

ENTENDENDO AS PORTAS E OS FIREWALLS

Um grupo diferente que não tem nenhuma relação com solicitações web, poderia ser transferido para a sala 80, ou a sala poderia ser simplesmente fechada, trancada e não ser mais usada. Os visitantes que tentassem encontrar a equipe web deveriam saber que ela agora está na sala 8080 , e não mais na sala 80. Um visitante que procurasse obter informações web na sala 80 após a equipe web ter sido transferida ficaria desapontado e não conseguiria obter as informações necessárias, pois não encontraria as pessoas corretas ou o escritório estaria trancado, enquanto um visitante que tivesse o endereço correto obteria a página web solicitada com a equipe do escritório novo que se encontra na sala 8080.

ENTENDENDO OS PROTOCOLOS IP

Os **protocolos** correspondem a **regras**, seja na **vida real** ou nas **redes** de computadores. Os diplomatas, os políticos e os oficiais de **alto escalão** **normalmente** possuem membros em suas equipes que lidam com questões de protocolo. Essas pessoas **garantem** que **todo visitante** seja recebido adequadamente ou que **todo** o pronunciamento oficial seja feito **corretamente**, no formato adequado, Utilizando as honrarias e os títulos apropriados. No mundo da computação esses **protocolos** garantem que a **comunicação** entre os sistemas ocorra **de acordo** com as **regras pré definidas**.

ENTENDENDO OS PROTOCOLOS IP

Embora haja uma **quantidade extremamente** grande de protocolos disponíveis para **todos** os **sistemas de computadores**, estaremos abordando os **3 principais** mais comumente usados por aplicações populares de **scanning no kali Linux**, utilizados para **aumentar a eficiência de scanning** e dos **testes de invasão** e para **potencializar a descoberta de vulnerabilidades**: o TCP, o UDP e o ICMP.

ENTENDENDO OS PROTOCOLOS IP



TCP

Um dos principais protocolos usados para comunicações em redes é o TCP.

O TCP é um protocolo de comunicação **orientado a conexão** o que significa que os computadores em cada extremidade do canal de comunicação **confirmam** que a **sessão está aberta** e que as mensagens estão sendo recebidas em cada lado da conexão. No passado muitas pessoas **relacionavam** essa comunicação há uma ligação telefônica:

TCP

O telefone toca:

Charlie: “Alô? ”

Denis: “oi, o Charlie está?”

Charlie: “Aqui quem fala é o Charlie!”

TCP

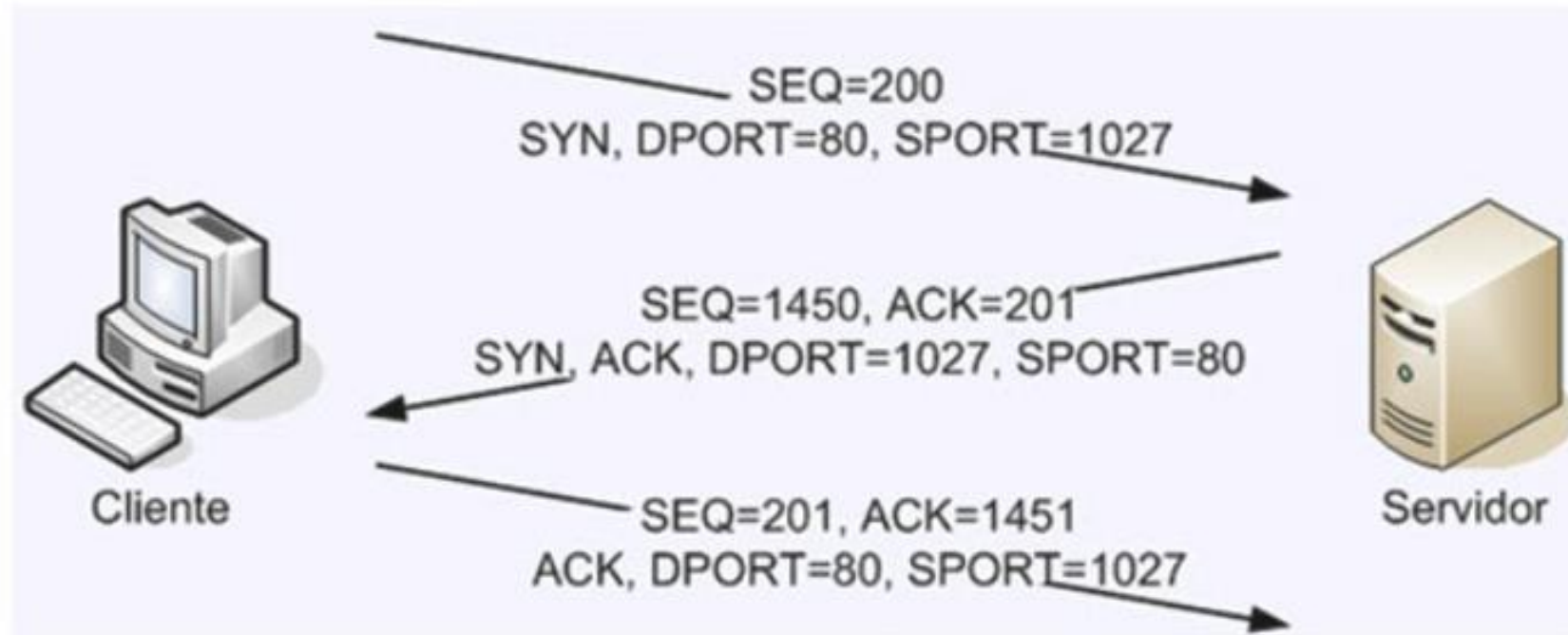
Aperto
de mão

Embora essa analogia seja um pouco antiquada, ela ilustra um **handshake** de 3 vias, pois é semelhante a conexão para iniciar uma comunicação TCP. Na comunicação TCP a comunicação é **iniciada** por pelo computador que estiver tentando se conectar com outro computador ocorrendo a troca de **3 pacotes**. Isto é feito por meio do envio de um pacote - ou solicitação - marcado com a flag de sincronização, o que recebe o nome de SYN.

TCP

Se o computador na extremidade **receptora** da comunicação estiver disponível, ele responderá **a quem enviou** um pacote contendo as flag de confirmação e de sincronização ligadas; esse pacote TCP é conhecido como **SYN/ACK**. Por fim, o computador que iniciou a comunicação envia um pacote com a flag de confirmação ligada (ACK) para concluir a sincronização e estabelecer a conexão. Essa comunicação ocorre conforme ilustrado na próxima imagem.

TCP



Cliente: Servidor, estás aí?? (SYN)

Servidor: Sim estou... (ACK) e tu, está aí? (SYN)

Cliente: Sim, estou... (ACK)

TCP

O Handshake de 3 vias corresponde ao método pelo qual **todas** as comunicações TCP **devidamente estabelecidas** têm início e ele garante que os computadores em ambas as extremidades do canal de comunicação estejam sincronizados um com o outro. É **extremamente** importante entender **o funcionamento** deste protocolo, para podermos compreender como ele **pode se tornar** uma **possibilidade** de **entrada** em um sistema. Logo estaremos explorando este **handshake** para ajudar a **identificar** os computadores da rede de modo a tentar **evitar** que sejam detectados.

TCP

Em processo de **confirmação continua**, ao longo da seção de comunicação entre os computadores (**pois isso ajuda a garantir** que as mensagens enviadas por um computador sejam **todas** recebidas por outro computador) e que **qualquer pacote que não conclua a viagem seja reenviado** pelo primeiro computador esse processo funciona de modo **semelhante** de respostas de comunicação de confirmação na **comunicação verbal**.

TCP

Denis: “Gostaria que você me encontrasse no restaurante às 15:00”

Charlie: “A que horas você gostaria de me encontrar no restaurante?”

Denis: “Às 15 horas”

Charlie: “Tudo bem, então será às 15 horas”.

TCP

sobrecarga

Isto cria bastante **overhead** na rede, geralmente provocando o **consumo de muita largura de banda** e fazendo com que as comunicações exijam um pouco mais de tempo. Por esse motivo, esse protocolo normalmente é usado para as seções de comunicação que precisem de **um nível mais elevado de confiabilidade** e que não sofra um impacto em **virtude da latência (atraso)** resultante de um pacote que chegar fora de ordem na extremidade distante (os programas que utilizam esse protocolo **reorganizam** os pacotes na ordem correta quando estes não chegam **na sequência**). Processos comuns que usam a comunicação **TCP** incluem a transferência de arquivos (**FTP**(file transfer protocol)) o tráfego web (**HTTP** (hyper text transfer protocol)), e o e-mail (**SMTP**(simple mail transfer protocol), **POP**(post office protocol) e **IMAP**(internet message access protocol)).

UDP

O **UDP** é um protocolo que apresenta **menos overhead** do que de conexões TCP. Se o processo de comunicação TCP é **análogo** a uma **chamada telefônica** em que ambas as partes garantem que a comunicação está sendo recebida à medida que é enviada por ambos os lados do canal da comunicação, o UDP assemelha-se mais a uma transmissão de rádio em que a comunicação é enviada por padrão, **nem sempre envia** e **nem quem recebe**, e **não verificam** se o pacote de comunicação foi recebido.

UDP

Estação de rádio:

“Esta é a rádio XHKA; juntem-se a nós hoje no restaurante às 15 horas”.

UDP

Essa transmissão é enviada pelo ar (no exemplo do rádio), e **se chegar** ao lado receptor, **ótimo**. Se uma parte da mensagem não foi recebida no destino, por padrão do protocolo, o receptor **não** pedirá que o pacote seja **retransmitido**.

Ao trabalhar com comunicação que utilizem o **UDP**, o lado receptor **não confirma** o status do link de comunicação **nem informa** se houve pacotes **descartados** durante a Transmissão.

UDP

Este método de comunicação com o **baixo overhead** é ideal para tarefas que **não** exijam a **validação** de cada pacote ou para serviços que não sofram impactos caso um pacote chegue fora da ordem. As aplicações que utilizam comunicação **UDP** **valorizam um baixo overhead** em **uma velocidade mais alta** em relação há um maior grau de confiabilidade por exemplo, as aplicações de **vídeo** e de **música**.

ICMP

O ICMP é um protocolo concebido para garantir a **saúde** e a **manutenção** da rede. Esse protocolo é usado para determinar se um **dispositivo** da rede está **funcionando** como deveria e para **verificar** se ele **pode se comunicar** adequadamente. Na maioria dos casos os **usuários finais nunca** usam diretamente as aplicações baseadas no ICMP, no entanto como ocorre com todas as regras, sempre há exceções. Nesse caso, o **traceroute** e o **ping** são bons exemplos de exceções. Outra diferença está no fato de que, de modo diferente das comunicações **TCP e UDP**, esse método de comunicação **não foi concebido** para transmitir **dados de usuários**.

ICMP

Em vez disso, o ICMP transporta mensagens **de sistema de e para** os **dispositivos de rede**, os computadores e os serviços de aplicações.

As mensagens ICMP possuem **um tipo** e **um código** específicos ou seja, um conjunto de números, em seus cabeçalhos. Esses conjuntos são usados para fazer perguntas ou para disponibilizar informações a respeito dos vários nós da rede e podem ajudar o **pentester** na determinação dos tipos de sistemas presentes no sistema **alvo**.

ICMP

Veja uma mensagem ICMP encapsulada num datagrama IP:

Título	Mensagem ICMP			
	Tipo (8 bits)	Código (8 bits)	Checksum (16 bits)	Mensagem (dimensão variável)

ICMP

Tipo	Código	Descrição
0 (Echo Reply)	0	Resposta de eco
3 (Destination Unreachable)	0	Rede destino inalcançável
	1	Host destino inacessível
	2	Protocolo destino inacessível
	3	Porta destino inacessível
	6	Rede destino desconhecida
	7	Host destino desconhecido
	9	Rede proibida administrativamente
	10	Host proibido administrativamente
	13	Comunicação proibida administrativamente
8 (Echo request)	0	Solicitação de eco

PING

O **Ping** provavelmente é comando baseado em ICMP usado com **mais frequência** pelo usuário final ou pelo administrador.

O comando **Ping** envia um pacote **ICMP** com um tipo igual a **8** e um código igual a **0** indicando que esse pacote é uma **solicitação de eco**. Os computadores que receberam esse pacote que estiveram configurados para responder (**normalmente estão**, por padrão) responderão com um outro pacote ICMP com tipo igual a **0** e código igual a **0** indicando que é uma **resposta de eco**. um **Ping** e **uma resposta bem sucedidos** indicam que o sistema interrogado está em cooperação na rede,

PING

ou seja,

pode ser considerado um host ativo.

Uma solicitação ping efetuada a partir de uma plataforma Windows por padrão será enviada 4 vezes enquanto uma solicitação Ping feita a partir de um host Linux continuarão a ser enviadas até que sejam canceladas pelo usuário.

Para cancelar um ping do Linux tecle *control + c* , um Ping bem sucedido e um Ping com falha apresentam o seguinte aspecto:

PING (HOST ATIVO)

MacBook-Pro-de-Sylvio:~ sylviovieira\$ ping 192.168.0.1

PING 192.168.0.1 (192.168.0.1): 56 data bytes

64 bytes from 192.168.0.1: icmp_seq=0 ttl=64 time=3.727 ms

64 bytes from 192.168.0.1: icmp_seq=1 ttl=64 time=3.834 ms

64 bytes from 192.168.0.1: icmp_seq=2 ttl=64 time=5.183 ms

64 bytes from 192.168.0.1: icmp_seq=3 ttl=64 time=3.966 ms

4 packets transmitted, 4 packets received, 0.0% packet loss

PING (HOST INACESSÍVEL)

MacBook-Pro-de-Sylvio:~ sylviovieira\$ ping 192.168.0.11

PING 192.168.0.11 (192.168.0.11): 56 data bytes

64 bytes from 192.168.0.11: Destination host unreachable

64 bytes from 192.168.0.11: Destination host unreachable

64 bytes from 192.168.0.11: Destination host unreachable

64 bytes from 192.168.0.11: Destination host unreachable

4 packets transmitted, 4 packets received, 0.0% packet loss

TRACEROUTE

O **Traceroute** usa o comando **Ping** baseado em **ICMP** para descobrir quantos dispositivos diferentes existem entre o computador que iniciou o **traceroute** e o **alvo**. Esse comando funciona por meio da **manipulação do tempo de vida** (time to live) - ou TTL - dos pacotes. O TTL corresponde à **quantidade de vezes** que um pacote pode ser retransmitido pelo próximo host encontrado na rede, ou seja, aos **hops** (saltos).

TRACEROUTE

O comando é **iniciado** com um valor de **TTL = 1**, indicando que o pacote pode ir no máximo até o próximo dispositivo existente entre quem iniciou o comando e o alvo. O dispositivo receptor enviará de volta um pacote ICMP com um **tipo = 11** e **código = 0** que significa tempo expirado e o pacote será registrado em um log.

Quem enviou o comando **incrementará** o TTL de um e enviará a próxima série de pacotes ao próximo host.

TRACEROUTE

Os pacotes atingirão o seu tempo de vida esperado no próximo hop da rede, o que, por sua vez, fará o roteador que receber o pacote enviar outra resposta indicando que o tempo expirou. Esse processo continua até que o alvo seja alcançado e todos os hops no caminho tenham sido registrados, o que resultará na criação de uma lista com todos os dispositivos que estiverem entre o computador que iniciou o comando e o alvo .

TRACEROUTE

Isto pode ser “**mu**uito” útil a um pentester para determinar quais dispositivos estão presentes em uma rede. As plataformas Windows possui um TTL default igual a 128, as plataformas Linux começam com o TTL igual a 64 e os dispositivos de rede Cisco possui um TTL (**incrível**) de 255 (*não mostra no echo do comando*).

O comando Traceroute no Windows corresponde ao “*tracert*”. Em um sistema Linux como o kali, o comando traceroute. Um Tracert típico em um computador Windows tem um aspecto a seguir:

TRACEROUTE

```
C:\Users\Rasyania>tracert www.google.com
Rastreando a rota para www.google.com [172.217.28.228]
com no máximo 30 saltos:

  1      <1 ms      <1 ms      <1 ms      10.0.2.2
  2      3 ms      1 ms      1 ms      192.168.0.1
  3      12 ms     12 ms     10 ms     10.15.0.1
  4      15 ms     11 ms     11 ms     189.7.120.110
  5      27 ms     26 ms     26 ms     embratel-T0-2-0-0-4004-uacc03.ctamr.embratel.net
.br [200.211.44.13]
  6      41 ms     37 ms     39 ms     ebt-H0-10-0-2-tcore01.ctamc.embratel.net.br [200
.244.211.165]
  7      41 ms     38 ms     39 ms     ebt-B4101-tcore01.spomb.embratel.net.br [200.230
.243.22]
  8      36 ms     33 ms     33 ms     ebt-H0-4-1-0-agg04.spomb.embratel.net.br [200.23
0.243.86]
  9      36 ms     34 ms     35 ms     peer-B51-agg04.spomb.embratel.net.br [189.23.243
.2]
 10      38 ms     35 ms     37 ms     108.170.227.19
 11      38 ms     35 ms     35 ms     209.85.246.137
 12      39 ms     34 ms     34 ms     eze03s05-in-f228.1e100.net [172.217.28.228]

Rastreamento concluído.
C:\Users\Rasyania>_
```

TRACEROUTE

Muitas das ferramentas de scanning no kali usam protocolos como TCP, o UDP e o ICMP para mapear as redes alvo.

Ou resultado de uma fase de scanning bem-sucedida consiste em uma listagem contendo hosts, endereços IP, sistemas operacionais e serviços. Algumas ferramentas de scanning também podem identificar vulnerabilidades e descobrir os detalhes acerca dos usuários. Esses detalhes podem contribuir bastante para aperfeiçoar a fase de exploração de falhas, pois os ataques dessa fase poderão ser mais bem focados de acordo com as tecnologias, as vulnerabilidades ou os hosts específicos.

NMAP: O REI DOS SCANNERS

COMEÇAR AQUI EM 08/09/2025

O Nmap tem a capacidade de determinar não só quais computadores estão ativos na rede alvo como também, em muitos casos, pode determinar o sistema operacional as portas que estão ouvindo, os serviços e, possivelmente, as credenciais dos usuários.

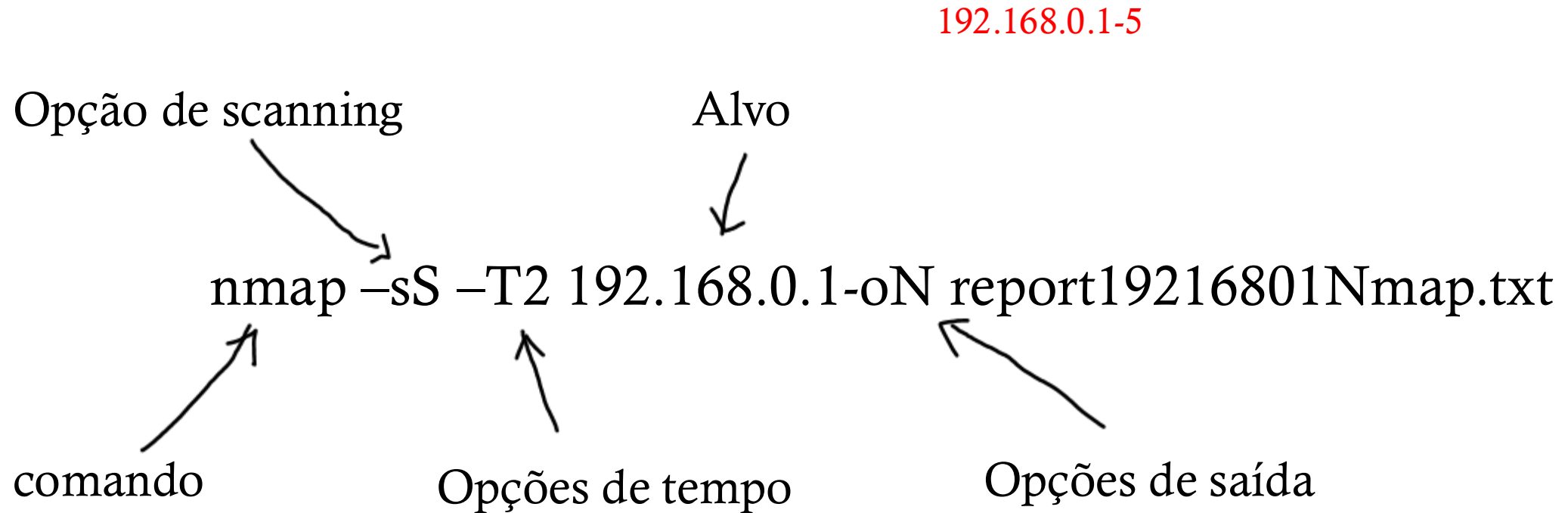
A usar uma combinação de comandos e opções contra os alvos, o Nmap pode ser um bem valioso na fase de scanning dos testes de invasão.

NMAP: ESTRUTURA

As opções de comando Nmap apresentam uma estrutura bem definida, o que permite que as opções do comando e os alvos sejam combinados de modo a permitir o máximo de flexibilidade.

Um comando típico, porém bem básico será mostrado no próximo slide, ele detalha as várias partes básicas que informa à ferramenta de scanning o que deverá ser feito.

NMAP: ESTRUTURA



```
root@kali:/home/kali# nmap -sS -T2 192.168.0.19 -oN reportNmap192168019.txt
```

```
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-04 14:03 EST
```

```
Nmap scan report for 192.168.0.19
```

```
Host is up (0.0010s latency).
```

```
Not shown: 977 closed ports
```

```
PORT      STATE SERVICE
```

21/tcp	open	ftp
22/tcp	open	ssh
23/tcp	open	telnet
25/tcp	open	smtp
53/tcp	open	domain
80/tcp	open	http
111/tcp	open	rpcbind
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
512/tcp	open	exec
513/tcp	open	login
514/tcp	open	shell
1099/tcp	open	rmiregistry
1524/tcp	open	ingreslock
2049/tcp	open	nfs
2121/tcp	open	ccproxy-ftp
3306/tcp	open	mysql
5432/tcp	open	postgresql
5900/tcp	open	vnc
6000/tcp	open	X11
6667/tcp	open	irc
8009/tcp	open	ajp13
8180/tcp	open	unknown

```
MAC Address: 08:00:27:A5:08:A7 (Oracle VirtualBox virtual NIC)
```

```
Nmap done: 1 IP address (1 host up) scanned in 407.02 seconds
```

```
root@kali:/home/kali#
```

```
#nmap -sS -T2 192.168.0.19 -oN reportNmap192168019.txt
```

NMAP: ESTRUTURA

As opções do comando informa ao **sistema operacional** que programa deve ser executado - nesse caso, o **nmap** - e o que é especificamente necessário para executar a tarefa de forma adequada. Após o comando encontram-se as opções de scanning nesse caso o **scan stealth** (escanear furtivamente) está sendo indicado pela opção **“-sS”**. A seguir estão as opções relacionadas aos tempos, que informam à ferramenta o volume de tráfego a ser gerado e com que velocidade, determinando, em última instância, se o scan será executado de forma rápida ou lenta.

NMAP: ESTRUTURA

Neste exemplo, a opção para o alvo vem depois das opções relacionadas ao tempo e é a única parte adicional obrigatória do comando, necessária a execução de um scan Nmap. A última opção nesse exemplo corresponde a opção para a saída, que informa à aplicação o local para o qual o resultado do scan deverá ser enviado. os comandos de scanning do Nmap podem ser muito mais complexos ou ainda, muito mais básicos que este apresentado, por exemplo:

```
#nmap 192.168.0.19
```

```
-rw-r--r-- 1 kali kali 807 Jul 27 13:33 .profile
drwxr-xr-x 2 kali kali 4096 Jul 27 13:37 Public
-rw-r--r-- 1 root root 892 Nov 4 14:10 reportNmap192168019.txt
drwxr-xr-x 2 kali kali 4096 Jul 27 13:37 Templates
```

```
root@kali:/home/kali# cat reportNmap192168019.txt
# Nmap 7.80 scan initiated Wed Nov 4 14:03:56 2020 as: nmap -sS -T2 -oN reportNmap192168019.txt 192.168.0.19
Nmap scan report for 192.168.0.19
Host is up (0.0010s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A5:08:A7 (Oracle VirtualBox virtual NIC)

# Nmap done at Wed Nov 4 14:10:43 2020 -- 1 IP address (1 host up) scanned in 407.02 seconds
```

NMAP: ESTRUTURA

#nmap 192.168.0.19

Neste exemplo, nenhuma opção para o alvo foi declarada, e o resultado foi rápido e padronizado.

Por padrão, o Nmap realizará um scan stealth do alvo que está em 192.168.0.19 usando a **velocidade** correspondente ao **template normal** de tempo, ou seja, **T=3**, caso nenhuma opção seja definida, como mostrado. Além do mais, os resultados do scan serão enviados somente ao monitor.

Os usos avançados incluem a execução de scripts detalhados criados para o Nmap por meio do NSE (Nmap Scripting Engine).

```
root@kali:/home/kali# nmap 192.168.0.19
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-04 13:37 EST
Nmap scan report for 192.168.0.19
Host is up (0.0015s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A5:08:A7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.53 seconds
root@kali:/home/kali#
```

NMAP: OPÇÕES DE SCANNING

O prefixo de scanning `-s` (**s minúsculo**) informa a ferramenta de scanning Nmap que o usuário está especificando um determinado tipo de scan a ser realizado no(s) alvo(s) definido(s) no comando de scan.

A seleção do tipo de scan pode ajudar o pentester a **evitar a detecção** por parte de alguns hosts e de **sistemas de proteção** baseados em rede e pode até mesmo ajudá-lo a se **desviar** de algumas proteções de rede, como os **firewalls**.

NMAP: OPÇÕES DE SCANNING

-sS Scan Stealth

Esse scan inicia uma conexão **TCP** com o alvo, porém nunca chega a concluir o handshake de 3 vias. A ferramenta Nmap inicia o handshake ao enviar um pacote **SYN** ao computador alvo. Esse, provavelmente responderá com um pacote **SYN/ACK** que não será confirmado por essa ferramenta. Com isso a conexão ficará aberta, pois o canal de comunicação **não** será totalmente estabelecido.

A maioria dos sistemas **fecha** automaticamente essa conexão após um determinado período de tempo.

NMAP: OPÇÕES DE SCANNING

-sS Scan Stealth

Em sistemas mais antigos, **configurados** de modo **indevido**, esse tipo de conexão pode **não ser detectada** de modo que esse tipo de scan normalmente é associado a um scan mais clandestino e mais discreto no alvo.

Atualmente, muitos sistemas de rede e até mesmo de hosts conseguem detectar o scan stealth, no entanto isso não deve impedir que o pentester use essa técnica de scanning, pois ela geralmente é mais **difícil de ser detectado** em relação a outros tipos de scans e, se o sistema alvo estiver configurado **indevidamente**, o scan poderá passar totalmente **despercebido** mesmo nos dias de hoje.

```
root@kali:/home/kali# nmap -sS 192.168.0.19
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-04 15:28 EST
Nmap scan report for 192.168.0.19
Host is up (0.00060s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A5:08:A7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.37 seconds
root@kali:/home/kali#
```

NMAP: OPÇÕES DE SCANNING

-sT Scan TCP connect

O scan TCP connect pode ser usado para coletar mais informações sobre o alvo do que o scan stealth e é capaz de fazer, pois uma conexão TCP completa é estabelecida com o host alvo. Neste caso a ferramenta Nmap inicia com um pacote *SYN*, que provavelmente será confirmado pelo alvo por meio de uma resposta *SYN/ACK*. De modo diferente de um Scan Stealth, a ferramenta dessa vez irá completar o estabelecimento da comunicação enviando um pacote *ACK* final. Esse Scan é registrado em log na maioria dos sistemas, porém geralmente pode fornecer mais informações que o scan stealth.

```
root@kali:/home/kali# nmap -sT 192.168.0.19
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-04 15:39 EST
Nmap scan report for 192.168.0.19
Host is up (0.0050s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A5:08:A7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.38 seconds
root@kali:/home/kali#
```

```
root@kali:/home/kali# nmap -sS 192.168.0.19
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-04 15:28 EST
Nmap scan report for 192.168.0.19
Host is up (0.00060s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A5:08:A7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.37 seconds
root@kali:/home/kali#
```

```
root@kali:/home/kali# nmap -sT 192.168.0.19
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-04 15:39 EST
Nmap scan report for 192.168.0.19
Host is up (0.0050s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:A5:08:A7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.38 seconds
root@kali:/home/kali#
```

NMAP: OPÇÕES DE SCANNING

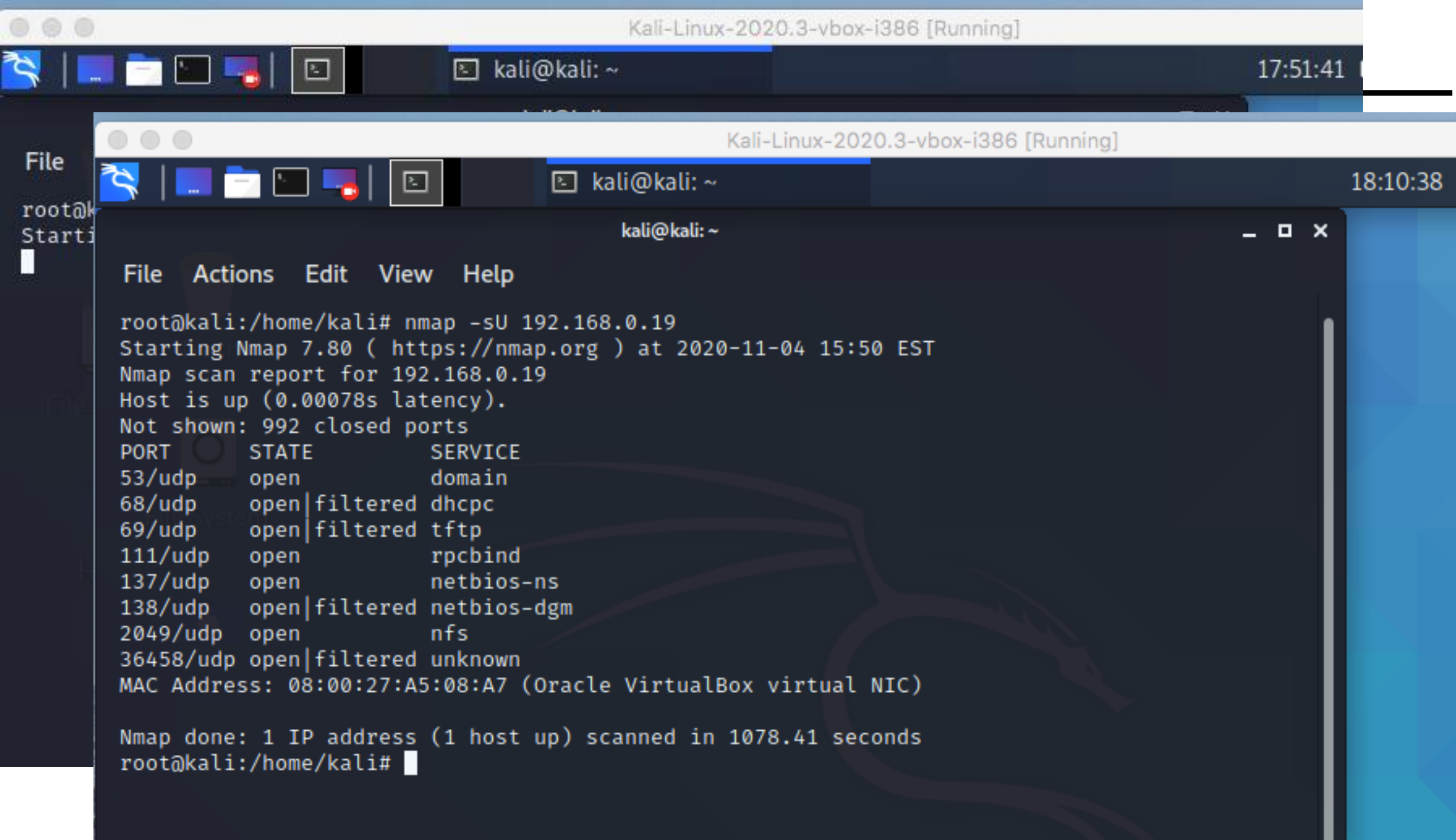
-sU Scan UDP

O scan UDP faz avaliação das portas UDP do sistema alvo. De modo diferente do scan de portas TCP, os scans UDP esperam receber respostas dos sistemas cujas portas testadas estejam fechadas. Os **pacotes enviados** as portas **UDP abertas não recebem resposta**; porém se o pacote enviado causar a geração de uma resposta pelo alvo, então a **porta** sendo verificado estará **aberta**. se nenhuma resposta foi recebida, a porta **poderá estar aberta** ou poderá estar sendo **filtrada** por um **dispositivo**, por exemplo um firewall. Portas **UDP fechadas** podem ser identificadas por uma resposta de **ICMP** com um tipo igual a 3 e código igual a 3 (**porta inacessível**).

NMAP: OPÇÕES DE SCANNING

-sU Scan UDP

Por fim, as portas com confirmação que estão sendo filtradas terão uma resposta ICMP com um tipo igual a 3 e códigos iguais a um 1, 2, 9, 10 ou 13, indicando vários erros de inacessibilidade.



Kali-Linux-2020.3-vbox-i386 [Running]

kali@kali: ~

17:51:41

Kali-Linux-2020.3-vbox-i386 [Running]

kali@kali: ~

18:10:38

kali@kali: ~

File Actions Edit View Help

root@kali:/home/kali# nmap -sU 192.168.0.19

Starting Nmap 7.80 (<https://nmap.org>) at 2020-11-04 15:50 EST

Nmap scan report for 192.168.0.19

Host is up (0.00078s latency).

Not shown: 992 closed ports

PORT	STATE	SERVICE
------	-------	---------

53/udp	open	domain
--------	------	--------

68/udp	open filtered	dhcp
--------	---------------	------

69/udp	open filtered	tftp
--------	---------------	------

111/udp	open	rpcbind
---------	------	---------

137/udp	open	netbios-ns
---------	------	------------

138/udp	open filtered	netbios-dgm
---------	---------------	-------------

2049/udp	open	nfs
----------	------	-----

36458/udp	open filtered	unknown
-----------	---------------	---------

MAC Address: 08:00:27:A5:08:A7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1078.41 seconds

root@kali:/home/kali#

SITE DO NMAP EM PORTUGUÊS

- [Exemplos | Guia de Referência do Nmap \(Página do Manual\)](#)
- Façam testes com o NMAP e escrevam um tutorial sobre ele!